

Security+ 3.2 · Secure Infrastructures

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 3.2 — Secure Infrastructures (5:54)

· [Vídeo no YouTube ↗](#)

Resumo da Aula: Security zones (DMZ pra público, interno atrás); attack surface (menor possível); conectividade nova = risco novo. Onde colocas cada serviço DETERMINA o quanto ele é atacado.



Highlights que a prova cobra

- Zonas: DMZ separa público do interno
- Attack surface: minimiza tudo o que é acessível
- Cada nova conexão = porta nova pro atacante



Dicas de prova & Cenários Típicos

- 'place public services between internet and internal network' = DMZ

Cenário clássico de exame: 'coloca o web service numa zona que pode falar com internet mas NÃO com o interno' = DMZ/screened subnet.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 3.2)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Secure Infrastructures) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Modelos de Responsabilidade Compartilhada na Nuvem:**
 - **IaaS (Infrastructure as a Service):** provedor cuida da infraestrutura física/hipervisor; cliente cuida de SO, patches, middleware, rede e dados.
 - **PaaS (Platform as a Service):** provedor cuida do hardware, SO e runtime; cliente cuida do código da aplicação e dos dados.
 - **SaaS (Software as a Service):** provedor gerencia tudo; cliente é responsável apenas pelas configurações de acesso e segurança dos próprios dados.
- **Segmentação de Rede e Segurança Perimetral:**
 - **DMZ (Demilitarized Zone):** sub-rede perimetral intermediária para servidores públicos (web, mail), isolada da rede corporativa interna por firewalls.
 - **VLANs (Virtual LANs):** isolamento lógico de tráfego na camada 2 para separar departamentos sensíveis (ex: finanças, RH, visitantes).
 - **SASE (Secure Access Service Edge):** convergência de SD-WAN e serviços de segurança em nuvem (CASB, FWaaS, ZTNA) entregues próximos ao usuário.
- **Resiliência e Tolerância a Falhas de Armazenamento:**
 - **RAID 0:** striping sem tolerância a falhas (foco exclusivo em velocidade; perda de 1 disco destrói tudo).
 - **RAID 1:** espelhamento (tolera perda de 1 disco; consome 50% do espaço total).
 - **RAID 5:** paridade distribuída (mínimo 3 discos; tolera falha de 1 disco).
 - **RAID 6:** dupla paridade (mínimo 4 discos; tolera falha simultânea de até 2 discos).
 - **RAID 10 (1+0):** combinação de espelhamento e striping (alta performance e redundância).

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- RAID NÃO substitui Backup. Se um arquivo for corrompido, excluído ou criptografado por ransomware, o RAID replica o dado corrompido instantaneamente nos discos espelhados.
- Na nuvem pública, a responsabilidade sobre a classificação e sigilo dos DADOS é SEMPRE do cliente em qualquer modelo (IaaS, PaaS ou SaaS).

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:

- A)** VLAN de voz
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

2. Você aluga só a máquina virtual e gerencia o SO e tudo acima. Que modelo é?

- A)** SaaS
- B)** PaaS
- C)** IaaS
- D)** On-premises

3. Qual modelo de serviço de nuvem oferece maior controle sobre a infraestrutura, incluindo sistema operacional e middleware?

- A)** SaaS
- B)** PaaS
- C)** IaaS
- D)** FaaS

4. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Zonas: DMZ separa público do interno'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Zonas: DMZ separa público do interno...

5. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Attack surface: minimiza tudo o que é acessível'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Attack surface: minimiza tudo o que é acessível...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Cada nova conexão = porta nova pro atacante'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cada nova conexão = porta nova pro atacante...

7. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'place public services between internet and internal network' = DMZ'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'place public services between internet and internal network' = DMZ...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: "coloca o web service numa zona que pode falar com internet mas NÃO com o interno"=DMZ/screened subnet.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'coloca o web service numa zona que pode falar com internet mas NÃO com o i...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Zonas: DMZ separa público do interno'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Zonas: DMZ separa público do interno...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Attack surface: minimiza tudo o que é acessível'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Attack surface: minimiza tudo o que é acessível...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — DMZ (screened subnet).

✓ **Por que está certa:** DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno.

✗ **Por que as outras estão erradas:**

- *VLAN de voz*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *VPN*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Intranet*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) C — IaaS.

✓ **Por que está certa:** IaaS (Infra as a Service) = provedor dá a infra (VM, rede, storage) e você cuida do SO pra cima. Ex: EC2. PaaS entrega a plataforma pronta; SaaS entrega o app pronto (ex: Gmail).

✗ **Por que as outras estão erradas:**

- *SaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *PaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *On-premises*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) C — IaaS.

✓ **Por que está certa:** IaaS provê infraestrutura virtualizada (servidores, armazenamento, rede) com controle total sobre OS e middleware.

✗ **Por que as outras estão erradas:**

- *SaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *PaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *FaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) D — Implementar a solução correspondente: Zonas: DMZ separa público do interno....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Zonas: DMZ separa público do interno.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: Attack surface: minimiza tudo o que é acessível....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Attack surface: minimiza tudo o que é acessível.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Cada nova conexão = porta nova pro atacante....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Cada nova conexão = porta nova pro atacante.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: 'place public services between internet and internal network' = DMZ....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): 'place public services between internet and internal network' = DMZ.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'coloca o web service numa zona que pode falar com internet mas NÃO com o i....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): 'coloca o web service numa zona que pode falar com internet mas NÃO com o interno'=DMZ/screened subnet..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: Zonas: DMZ separa público do interno....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Zonas: DMZ separa público do interno.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Attack surface: minimiza tudo o que é acessível....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Attack surface: minimiza tudo o que é acessível.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

